INFORME TÉCNICO DE AUDITORÍA CRIPTOGRÁFICA

Evaluación de Cumplimiento de la Política de Contraseñas

Asignatura: Seguridad en Sistemas de Información e Internet | **Grupo:** Grupo 2
Autores: Raimundo García Pérez, Konstantinos Peridis | **Fecha:** 11 de Septiembre de 2026

Resumen Ejecutivo

A petición de la entidad financiera, el equipo de auditoría ha evaluado la seguridad de las credenciales de acceso de tres cuentas de usuario sospechosas en la base de datos de control de accesos (`mjimenven`, `jmquevedo` y `rhgasca`). El propósito central consistió en determinar si las contraseñas almacenadas se ajustan a la Política de Seguridad corporativa, la cual estipula una longitud mínima de 8 caracteres y la presencia obligatoria y simultánea de mayúsculas, minúsculas, dígitos numéricos y símbolos especiales.

A través de la inspección de la longitud de los registros (40 caracteres hexadecimales / 160 bits), se constató el uso de la función de dispersión **SHA-1**. En un entorno de pruebas controlado y reproduciendo las pistas aportadas por los propios usuarios, se desplegó la herramienta **Hashcat**, logrando **recuperar en claro el 100% de las contraseñas investigadas** en cuestión de segundos.

El dictamen técnico concluye que **la totalidad de los usuarios analizados incumple de manera manifiesta la Política de Seguridad**. Este resultado confirma la ausencia de controles técnicos de validación previa en los módulos de autenticación y registro de la entidad, dejando la seguridad supeditada al criterio arbitrario de los empleados.

1. Identificación del Algoritmo y Comandos Ejecutados

Los tres resúmenes almacenados en la base de datos presentan 40 dígitos hexadecimales, lo que certifica el uso del algoritmo de dispersión **SHA-1** (`-m 100`). Al operar en una máquina virtual sin soporte directo de GPU física, se ejecutó Hashcat sobre la CPU virtual mediante los modificadores `-D 1` y núcleos optimizados `-O`.

Usuario 1: Manuel Jimen Ventoyk (`mjimenven`)

- **Hash SHA-1:** `26967c61a7f5442fb47861f812126ccf02a65bde`
- **Pista del usuario:** Afirmó haber puesto una palabra inusual del diccionario de la RAE.
- **Técnica:** Ataque por diccionario simple (`-a 0`) empleando el corpus léxico `diccionario-rae-completo.txt`.
- **Comando ejecutado:**

```
hashcat -m 100 -a 0 -D 1 -O hash1.txt ~/Desktop/diccionario-rae-completo.txt
```

- **Contraseña recuperada:** `vituperio` (tiempo de resolución: $<$ 1 segundo).

Usuario 2: José María Quevedo Yuw (`jmquevedo`)

- **Hash SHA-1:** `b1b3773a05c0ed0176787a4f1574ff0075f7521e`
- **Pista del usuario:** Declaró haber seleccionado una de las contraseñas comunes habituales.
- **Técnica:** Ataque por diccionario simple (`-a 0`) sobre la lista global de contraseñas `rockyou.txt`.
- **Comando ejecutado:**

```
hashcat -m 100 -a 0 -D 1 -O --segment-size=1 hash2.txt /usr/share/wordlists/
    rockyou.txt
```

- **Contraseña recuperada:** `qwerty` (patrón clásico de teclado de 6 caracteres).

Usuario 3: Rafael Hidalgo Gasca (`rhgasca`)

- **Hash SHA-1:** `35a9c2444ec63ee39f3b214edb9011f32e624a28`
- **Pista del usuario:** Señaló haber jugado con letras de su nombre y apellidos con un número al final.
- **Técnica:** Ataque de fuerza bruta dirigida con máscara (`-a 3`). Se acotó el espacio de búsqueda definiendo un conjunto personalizado (`-1 rafelehidalgosc`) que evalúa combinaciones de 6 letras de su identidad seguidas de un dígito decimal (`?1?1?1?1?1?1?d`).
- **Comando ejecutado:**

```
hashcat -m 100 -a 3 -D 1 -O -1 rafelehidalgosc hash3.txt ?1?1?1?1?1?1?d
```

- **Contraseña recuperada:** `aaeiao5` (las vocales ordenadas de su nombre y apellidos más el dígito 5).

2. Matriz de Cumplimiento de la Política de Seguridad

Las directivas de autenticación de la entidad exigen: **R1** (Longitud ≥ 8), **R2a** (Letras mayúsculas y minúsculas), **R2b** (Al menos un número 0–9) y **R2c** (Al menos un símbolo especial permitido).

Usuario	Username	Contraseña	R1 ($\geq$8)	R2a (A/a)	R2b (0-9)	R2c (Símb.)
Manuel Jimen	`mjimenven`	`vituperio`	CUMPLE (9)	INCUMPLE	INCUMPLE	INCUMPLE
José María Q.	`jmquevedo`	`qwerty`	INCUMPLE (6)	INCUMPLE	INCUMPLE	INCUMPLE
Rafael Hidalgo	`rhgasca`	`aaeiao5`	INCUMPLE (7)	INCUMPLE	CUMPLE ('5')	INCUMPLE

Cuadro 1: Evaluación individualizada del cumplimiento de la Política de Contraseñas.

Detalle específico de infracciones por usuario:

- **Manuel Jimen Ventoyk:** Vulnera las reglas **2a, 2b y 2c** (únicamente cumple la longitud con 9 letras minúsculas).
- **José María Quevedo Yuw:** Vulnera las reglas **1, 2a, 2b y 2c** (incumplimiento total; clave trivial de 6 letras).
- **Rafael Hidalgo Gasca:** Vulnera las reglas **1, 2a y 2c** (solo cumple la presencia del número 5; faltan símbolos y mayúsculas, y su longitud es de 7 caracteres).

Conclusiones Técnicas

1. **Inexistencia de barrera técnica de validación:** El sistema carece de filtros previos en backend, permitiendo que contraseñas que violan frontalmente la política corporativa sean aceptadas e insertadas en la base de datos.
2. **Uso de funciones de dispersión inadecuadas:** SHA-1 es un algoritmo rápido de integridad general, no una función robusta para credenciales. Permite tasas de cálculo de millones de evaluaciones por segundo con hardware común.
3. **Vulnerabilidad ante patrones humanos:** Los usuarios eligen atajos predecibles (términos de diccionario, secuencias de teclado o derivaciones de sus propios nombres), neutralizando contraseñas aparentemente complejas.

Recomendaciones de Seguridad

1. **Filtro técnico previo (Script de validación):** Incorporar una rutina de validación que verifique las cuatro directivas antes de autorizar la inserción o modificación en base de datos (véase Anexo I).
2. **Avisos y concienciación en interfaz:** Mostrar mensajes dinámicos desaconsejando explícitamente el uso de nombres, apellidos, fechas o patrones de teclado en los formularios de registro.
3. **Autenticación de doble factor y biometría:** Desplegar esquemas 2FA/MFA o identificación por huella dactilar para que la seguridad no dependa exclusivamente de una clave estática.

4. **Aplicación de Salting (Sal criptográfica):** Concatenar a cada contraseña una cadena aleatoria y única antes de computar el resumen. Esto garantiza que contraseñas idénticas generen hashes completamente diferentes, invalidando el uso de diccionarios precalculados y ataques simultáneos.

Propuesta de Servicios de Consultoría: SecurTech Advisory

Ante las deficiencias detectadas, la firma consultora **SecurTech Advisory** ofrece a la entidad un plan integral de remediación y acompañamiento técnico:

- **Auditoría Integral de Control de Acceso y Gestión de Identidades (IAM):**
  - Inspección forense completa de las tablas de usuarios para identificar credenciales débiles o comprometidas.
  - Plan de saneamiento y migración hacia esquemas criptográficos robustos con salting individual por usuario.
- **Implementación e Integración de Medidas Técnicas:**
  - Integración de módulos de filtrado estricto en la capa de aplicación (PHP / API de backend).
  - Despliegue de mecanismos de autenticación multifactor (TOTP, FIDO2/WebAuthn) y verificación biométrica.
  - Incorporación de medidores de entropía y alertas en tiempo real en los portales de autoservicio.
- **Capacitación y Cultura de Seguridad (Security Awareness):**
  - Talleres orientados al personal sobre riesgos derivados de la ingeniería social y la elección de claves predecibles.

Bibliografía

- Materiales y presentaciones teóricas de la asignatura *Seguridad en Sistemas de Información e Internet*.
- Repositorio de palabras en castellano: `diccionario-rae-completo.txt` (https://github.com/fvillena/palabras-diccionario-rae-completo).
- Documentación técnica y manual de referencia de **Hashcat** (v7.x): https://hashcat.net/wiki/.

Relación de Anexos

- **Anexo I:** Módulo de Validación de Contraseñas y Registro Seguro en PHP (`validador_password.php`). Demostración práctica de la rutina de validación previa integrada en la función `addNewUser` estudiada en la asignatura.

Anexo I: Script de Validación de Contraseñas en PHP

El siguiente módulo implementa la lógica de control técnico de la Política de Seguridad y se acopla directamente a la función de alta de usuarios (`addNewUser`) analizada en la asignatura:

```php
<?php
/**
 * Anexo I: Modulo de Validacion y Registro de Usuarios.
 * Valida el cumplimiento de la Politica de Seguridad antes del almacenamiento.
 */

/**
 * Verifica si la clave satisface las 4 reglas de la organizacion:
 * 1. Longitud minima de 8 caracteres.
 * 2. Al menos una mayuscula y una minuscula.
 * 3. Al menos un digito numerico (0-9).
 * 4. Al menos un simbolo del conjunto permitido.
 *
 * @param string $password
 * @return bool True si es conforme, False si incumple alguna directiva.
 */
function validatePasswordPolicy($password) {
    // Regla 1: Longitud minima de 8 caracteres
    if (strlen($password) < 8) {
        return false;
    }

    // Regla 2a: Al menos una mayuscula y una minuscula
    if (!preg_match('/[A-Z]/', $password) || !preg_match('/[a-z]/', $password)) {
        return false;
    }

    // Regla 2b: Al menos un caracter numerico
    if (!preg_match('/[0-9]/', $password)) {
        return false;
    }

    // Regla 2c: Al menos un simbolo especial permitido
    if (!preg_match('/[!@#\$%&\*\^\(\)\-=\{\}\[\]\\\:;<>\?,\.\/]/', $password)) {
        return false;
    }

    return true;
}

/**
 * Registra un nuevo usuario aplicando validacion previa.
 *
 * @param string $username
 * @param string $password
 * @return int 0: Exito, 1: Password no valido por politica, 2: Error en BD.
 */
function addNewUser($username, $password) {
    global $connection;

    // Control previo: Validacion tecnica de la politica
    if (!validatePasswordPolicy($password)) {
        return 1; // Rechazado por incumplimiento de directivas
    }

    // Saneamiento de entrada segun criterio visto en clase
    $username = str_replace("'", "''", $username);

    // Generacion del resumen criptografico (SHA-1 segun enunciado)
    $password = sha1($password);
```

```
    $q = "INSERT INTO " . TBL_USERS . " VALUES ('$username', '$password')";
    $result = mysql_query($q, $connection);

    if ($result) {
        return 0; // Insercion completada correctamente
    } else {
        return 2; // Fallo en la ejecucion de la consulta SQL
    }
}
?>
```